

Secure Web Application Development Two Day Hands-on Training Course Mon 10th / Tue 11th August 2026

Course Access URL https://teams.microsoft.com/dl/launcher/launcher.html?url=%2F%20%2F%2Fmeetup-join%2F19%3Ameeting_YmlxZjMONzUtdMDU2Mi00Y2RlTg2NzgtMmNmMTAzNzdiZWU2%40thread.v2%2F0%3Fcontext=%2527b%2522Tid%2522%253a%2522f1d10e5b-f823-4b3b-9f5a-94f93bad08e7%2522%252c%2522Oid%2522%253a%25221455b6ce-97e9-4117-b340-92cbff0c4a8b%2522%2527d%26anon=true&type=meetup-join&deeplinkid=c6f7c778-062d-46a8-aaa1-3c2d94f02e5f&directDL=true&msLaunch=true&enableMobilePage=true&suppressPrompt=true

Meeting ID: 319 707 804 348 3
Passcode: wo3xv2fz

Day 1 of 2 - “Fundamentals & First Exploits”

Module 1: Introductions, course overview & starting surveys	09:30 to 10:30
- targeted WebAppSec quizzes with instant feedback to activate delegates' learning - reviewing lab environment handout describing Wireshark, ZAP Proxy, Juice Shop etc. - connecting to & getting familiar with the course's hands-on Linux lab environment - previews of Day 1 & Day 2 content to prepare delegates to engage with WebAppSec Practicals: each delegate will access an individual cloud-hosted Linux VM (via RDP or HTTPS)	
Morning Break 1: 15 mins	10:30 to 10:45
Module 2: Understanding Web Applications	10:45 to 11:45
- exploring HTML, Cascading Style Sheets & JavaScript using Modern Web Browsers - enabling & making use of Browser Developer Tools (F12) - understanding legal, ethical & data protection considerations related to WebAppSec - inspecting HTTP verbs, Headers, Cookies & data using ZED Attack Proxy (ZAP) Practicals: delegates will perform all of this module's activities in their Linux VM labs	
Morning Break 2: 15 mins	11:45 to 12:00
Module 3: Information Security & Cybersecurity Fundamentals	12:00 to 13:00
- appreciating the significance of availability, confidentiality & integrity for Web Apps - performing simulated phishing & browser-hooking attacks using BeEF Project - understanding the meaning of threats, vulnerabilities, exploits, incidents & controls Practicals: delegates will perform the simulated phishing activities in their Linux VM labs	
Lunch Break: 60 mins	13:00 to 14:00
Module 4: Introducing WebAppSec Good Practices	14:00 to 15:00
- introducing OWASP, the OWASP Top 10:2025 & the OWASP Web Application Threat model - understanding relationships between OWASP, CWEs, CVEs, CVSS & MITRE ATT&CK - considering how IAST tools (like ZAP & Burp Suite) differ from SAST & DAST tools Practicals: delegates will identify & remediate vulnerabilities within their Linux VM labs	
Afternoon Break 1: 15 mins	15:00 to 15:15
Module 5: A01 Broken Access Control & A07 ID & Authentication Failures	15:15 to 16:15
- understanding the nature of Identification, Authentication & Access Control - overview of authn. options for BBC (BBC Login, BBC Account, Access Foundations) - how to design secure Web Apps based on proven Identity & Access Control methods Practicals: delegates will perform & critically assess authentication & access control attacks	
Afternoon Break 2: 15 mins	16:15 to 16:30
Module 6: A05 Injection	16:30 to 17:30
- experiencing the significance of Cross-Site Scripting (XSS) attacks with hands-on examples - how to identify & mitigate SQL Injection, Command Injection & SSRF vulnerabilities - appreciating how injection results from poor data/code separation & unvalidated inputs Practicals: delegates will perform injection attacks (incl. XSS & SQLi) in their Linux VM labs	
End of Day 1	17:30

Secure Web Application Development Two Day Hands-on Training Course Mon 10th / Tue 11th August 2026

Day 2 of 2 - "Secure Development & the OWASP Top 10:2025"

Module 7: Secure Web App Development Lifecycles & Supporting Tools	09:30 to 10:30
- in breakout groups, review the 4 leading SSDLC models: Microsoft SDL, OpenSAMM, BSIMM, SafeCode - understanding the value of OWASP's Application Security Verification Standard (ASVS) - understanding where SAST, DAST, IAST & SCA tools fit within the SSDLC - introducing ShopCo, the course's deliberately vulnerable Flask application Practicals: SSDLC activities include both lab tasks & group discussions in breakout rooms	
Morning Break 1: 15 mins	10:30 to 10:45
Module 8: A02 Security Misconfiguration & A03 Software Supply Chain Failures	10:45 to 11:45
- using legal Open Source Intelligence (OSINT) methods to identify externally exposed vulnerabilities - showing how DNS, Shodan & Certificate Transparency records can expose internal assets - exploring good practices for hardening & patching Web Applications Practicals: OSINT activities may be performed either using Linux VM labs or own computer	
Morning Break 2: 15 mins	11:45 to 12:00
Module 9: A04 Cryptographic Failures & A08 Software & Data Integrity Failures	12:00 to 13:00
- examining the meaning & impacts of software integrity failures - performing tampering attacks to manipulate integrity of data including scores & prices - breaking TLS security by installing untrusted Root Certificates in Firefox lab environment Practicals: delegates will perform attacks which bypass or defeat integrity & encryption mechanisms	
Lunch Break: 60 mins	13:00 to 14:00
Module 10: A06 Insecure Design & A10 Mishandling of Exceptional Conditions	14:00 to 15:00
- understanding the need for Threat Modelling & how to Threat Model every change - identifying Excessive Data Exposure, Missing Authorization & unsafe handling of malformed inputs Practicals: delegates will threat model & probe error-handling defences in their Linux VM labs	
Afternoon Break 1: 15 mins	15:00 to 15:15
Module 11: A09 Logging & Alerting Failures	15:15 to 16:15
- how to design & implement detection, response & recovery solutions (NIST Cybersecurity Framework) - reinforcing need for Threat Model driven WebAppSec lifecycle (as per Module 10) - configuring & managing error handling, security logging & monitoring solutions Practicals: delegates will perform relevant activities using the OWASP Juice Shop demo app	
Afternoon Break 2: 15 mins	16:15 to 16:30
Module 12: Supporting continuous Web Application Security improvements	16:30 to 17:30
- reflecting on learnings from this course & how to improve WebAppSec within the BBC - signposting trusted sources of further relevant information about WebAppSec - completing end-of-course feedback to improve future runs of this course Practicals: delegates will access online surveys & quizzes to reinforce their learning	
End of Day 2, End of Course.	17:30

Secure Web Application Development Two Day Hands-on Training Course Mon 10th / Tue 11th August 2026

Lab Resources:

- Cloud Hosted Ubuntu Linux Virtual Machines – 1 per delegate (up to 10 delegates)
- Selected Kali Linux tools e.g. BeEF Project, HashCat, SE Toolkit, ZAP Proxy
- Selected elements of vulnerable apps e.g. OWASP Juice Shop, DVWA, ShopCo, Google XSS-Game & Gruyere.
- Selected Websites & OSINT sources e.g. OWASP, MITRE, NIST CVE, FIRST CVSS, SafeCode, Shodan

Pre-Course Preparation:

1. All delegates should pre-install client software which supports Remote Desktop Protocol (RDP) e.g.

Windows Remote Desktop (for Windows 10/11)

- simply type Remote Desktop into Windows search: either it will already be installed or you should be presented with an option to install it.

Microsoft Remote Desktop (for Macs)

- if this is already installed, you should be able to find Microsoft Remote Desktop within the Applications folder. If it is not already installed, please use the Apple App Store (or BBC equivalent) to download it.

Please contact BBC IT support if you have any difficulties installing RDP client software.

2. Just before the course (before 9:30am on Mon 10th August 2026) you will be sent an email containing 2 pieces of information which you will need to configure your RDP client. There's no need to do anything before the start of the course because your instructor will demonstrate how to set-up your RDP client, but if you already know how to set-up your RDP client feel free to connect to the labs using these details. The 2 pieces of information will be the:

IP Address of your assigned Linux VM; and the
Password for your assigned Linux VM – will remain constant for the whole course

(the User Name for all of your assigned Linux VMs will be **ubuntu** – lower case)

Unless you reboot your VM, your IP address will remain constant.

If you reboot your VM, a new IP address will be assigned (please ask your instructor for the new IP address).